BLACK BYT3

Offensive Security

+ AI Fellowship

Task Submission Report | Cohort 1.0

Name	Muhammad Hozaifa Naeem
Domain	Offensive Security + AI
Organization	Black Byt3
Task	Task 2 — Subdomain Enumeration Tool (Scanvora v5.1)
Date	April 21, 2026

Task Overview

This report documents the development of **Scanvora v5.1** — a Professional Subdomain Enumeration and Recon Engine built for the Black Byt3 Offensive Security + AI Fellowship (Cohort 1.0). The tool satisfies all four deliverables outlined in the Fellowship Task 2 specification issued by Jafar Ali (Lead — Black Byt3).

What I Had to Do

The task required building a complete subdomain enumeration and reconnaissance tool from scratch. The full requirements were:

1. Subdomain Enumeration	Implement two discovery methods: (a) Brute Force using a wordlist to probe subdomains, and (b) API-Based enumeration using external services such as VirusTotal, SecurityTrails, crt.sh, HackerTarget, AlienVault OTX, and the Wayback Machine to passively collect subdomains without noisy scanning.
2. Live Subdomain Check	After collecting all candidate subdomains from both methods, automatically verify which are live (actively responding) and discard dead or unresolved entries.
3. IP Extraction	From confirmed live subdomains, extract and classify each resolved IP address as either Private (RFC-1918 internal ranges) or Public (internet-routable). Separately identify and mark the origin IP of each subdomain.
4. Shodan Integration	For every public IP discovered, query the Shodan API to retrieve open ports, service banners, and associated CVE vulnerability data. Display this enrichment clearly in both the terminal summary and saved report files.
5. Name Banner	Display the author's name / alias (hyena11-MHN) as a styled ASCII art logo at tool startup.

How I Approached It

Architecture Decision — Fully Async Python

I chose Python 3 with an entirely asynchronous architecture using **asyncio**, **aiohttp**, and **aiodns**. This allows Scanvora to perform hundreds of concurrent DNS resolutions and HTTP probes simultaneously without blocking, making it dramatically faster than a sequential scanner. The tool is structured into modular classes so each responsibility (enumeration source, DNS resolver, HTTP prober, Shodan enricher) is cleanly separated.

Module Breakdown

Module / Class	Responsibility
ScanvoraWizard	Interactive CLI setup wizard. Guides the user step-by-step through domain input, scan mode se
WildcardDetector	Sends random-label DNS probes before scanning to fingerprint wildcard DNS responses. Any s
AsyncDNSResolver	Async DNS A-record resolver backed by aiodns. Resolves all candidate subdomains concurrent
HTTPProber	Async HTTP/HTTPS prober using aiohttp. Fetches status codes, page titles, server headers, an
PassiveOSINT Sources	Six independent async source classes: CrtShSource (Certificate Transparency logs), HackerTa
BruteForceEnumerator	Reads a wordlist and fires async DNS lookups for each word prepended to the target domain. S
ShodanEnricher	For each unique public IP in the results, queries the Shodan InternetDB API (free, no key) or the
Scanvora (main)	Orchestrates the full pipeline: OSINT + brute-force enumeration → dedup → wildcard filter → as

Priority Scoring System

Every discovered subdomain is assigned an automated priority score (0–100) based on its first DNS label. Labels associated with high-value targets in bug bounty and red team engagements (e.g., *admin*, *auth*, *api*, *vpn*, *jenkins*) score 80–100 and are flagged as CRITICAL in the terminal output. CDN and static-asset subdomains score 20–25. This lets analysts triage findings instantly.

Tool Features & Scan Modes

Scanvora v5.1 offers five scan modes accessible through the interactive wizard:

Mode	Description
1. Full Recon Scan	All sources enabled — brute force + all API/OSINT sources. Provides maximum coverage. Suita
2. Fast Scan	Limited source set for quick results. Uses only a subset of OSINT sources without brute force. Id
3. Brute Force Only	Wordlist-based DNS probing only. Useful when API keys are unavailable or passive OSINT is n
4. Passive OSINT Only	No brute force, no paid APIs. Queries crt.sh, HackerTarget, AlienVault OTX, Wayback Machine.
5. Exit	Graceful exit from the wizard.

Scan Pipeline Flow

- Step 1 — Interactive Wizard collects target domain, scan mode, concurrency, RPM, and optional API keys.
- Step 2 — Wildcard Detection fires random-label DNS queries to identify wildcard DNS entries.
- Step 3 — Enumeration Phase: OSINT sources (crt.sh, HackerTarget, AlienVault OTX, Wayback Machine, VirusTotal, SecurityTrails, Shodan host search) and/or Brute Force DNS are run concurrently.
- Step 4 — All discovered subdomains are normalised, lowercased, deduplicated, and merged into a single set.
- Step 5 — Async DNS + HTTP Probing: each candidate is resolved via aiodns and HTTP-probed via aiohttp. Dead subdomains and wildcard IPs are discarded.
- Step 6 — IP Classification: each resolved IP is categorised as Private (10.x, 172.16–31.x, 192.168.x) or Public.
- Step 7 — Shodan Enrichment: for every unique public IP, the Shodan API is queried for open ports and CVE identifiers.
- Step 8 — Summary printed to terminal with critical subdomain list, IP counts, and duration.
- Step 9 — Results saved as both a machine-readable JSON file and a human-readable TXT file.

Output Files

Every scan produces two timestamped output files in the working directory:

- **scanvora_<domain>_<timestamp>.json** — Full machine-readable report including all resolved subdomains, IP types, HTTP status, page titles, security headers, Shodan data, and per-subdomain priority and confidence scores.
- **scanvora_<domain>_<timestamp>.txt** — Human-readable report sorted by priority score, showing subdomain, IP, HTTP status, priority (P=), confidence (C=), and CVE count where available.

Script Overview — Scanvora v5.1

The tool is written as a single self-contained Python 3 file (**Scanvora5_1.py**). Below is a high-level class and method map — the full source is not reproduced here; only the structural outline is shown for reference.

Class / Component	Key Methods / Notes
ScanvoraWizard	_prompt(), _prompt_yn(), _prompt_int(), _prompt_choice(), run() — drives the entire interactive
WildcardDetector	detect() — sends N random-label probes; stores wildcard IPs in a set.
AsyncDNSResolver	resolve(subdomain) — returns first A-record IP or None; handles NXDOMAIN/timeout silently.
HTTPProber	probe(subdomain) — returns dict with live, status, title, server, tech, headers.
CrtShSource	enumerate() — fetches JSON from crt.sh CT log API; extracts name_value field.
HackerTargetSource	enumerate() — queries api.hackertarget.com/hostsearch.
AlienVaultOTXSource	enumerate() — pages through OTX passive DNS endpoint.
WaybackMachineSource	enumerate() — queries Wayback CDX API for URL patterns.
VirusTotalSource	enumerate() — uses v3 /domains/{domain}/subdomains endpoint (API key required).
SecurityTrailsSource	enumerate() — queries SecurityTrails subdomains endpoint (API key required).
ShodanSource	enumerate() — searches Shodan hostname:{domain} for associated hosts.
BruteForceEnumerator	run(wordlist_path) — async DNS resolution per word; returns resolved set.
ShodanEnricher	enrich(ip) — queries InternetDB or Shodan API; returns ports + CVE list.
Scanvora	_run_enumeration(), _probe_all(), _enrich_shodan(), _print_summary(), _save_report() — mast

Key Design Choices

Fully Async I/O: All network operations (DNS, HTTP, API calls) use Python asyncio with aiohttp and aiodns. This allows 40+ concurrent probes without threading overhead.

Rate Limiting: A configurable RPM (requests per minute) limiter prevents overwhelming target DNS servers or triggering API rate-limit blocks. Default: 120 RPM with concurrency of 40.

Wildcard Filtering: Wildcard DNS entries can pollute results with thousands of false positives. The detector runs before enumeration so every result set is pre-filtered.

Confidence Scoring: Each subdomain receives a confidence score (0–100) combining DNS resolution (+30), HTTP liveness (+40), page title presence (+15), server header (+10), and technology fingerprint (+5).

Graceful Shutdown: SIGINT / SIGTERM handlers save partial results to disk before exiting, ensuring no data is lost if the operator interrupts a long scan.

Tool in Action — Screenshots

Screenshot 1 — Tool Startup & Interactive Wizard

The ASCII banner displays the Scanvora logo with author handle **hyena11-MHN**. The interactive wizard then presents scan mode options.

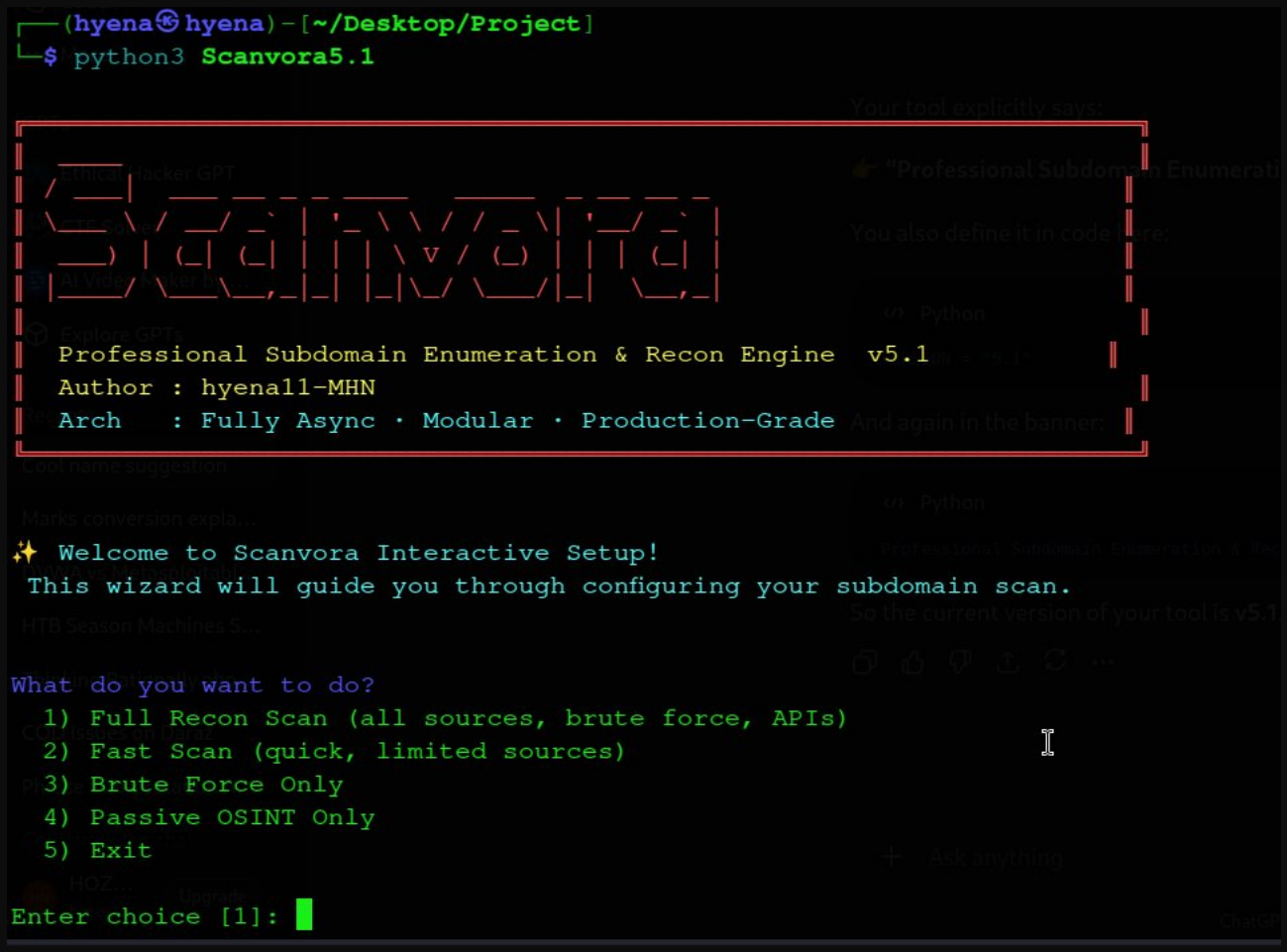

Fig 1: Scanvora v5.1 startup — ASCII banner and interactive scan mode selection.

Screenshot 2 — Scan In Progress

Passive OSINT is configured and the scan is running. The wizard confirms mode, concurrency (40), and RPM (120). Live INFO log lines show concurrent queries to crt.sh, HackerTarget, AlienVault OTX, and the Wayback Machine.

```
Enter target domain (e.g., example.com): hackthissite.org
  ✅ Domain: hackthissite.org

=== Passive OSINT Configuration ===
  ℹ️ Passive OSINT: no brute force, no Shodan/paid APIs

Enable crt.sh? [Y/n]: t
Enable Wayback Machine? [Y/n]: t
Enable AlienVault OTX? [Y/n]: y
  ✅ Passive OSINT configured
=== Optional API Keys ===
  ℹ️ Leave blank to skip (scans work without these)

Add premium API keys? [y/N]: n
═══════════════════════════════════════════════════════════════
  SCAN CONFIGURATION SUMMARY
═══════════════════════════════════════════════════════════════

  🎯 Domain              : hackthissite.org
  📋 Mode                : OSINT
  💪 Concurrency         : 40
  ⏱️ Rate limit (RPM)    : 120
  🔨 Brute force         : Disabled
  🌐 API sources         : Enabled

═══════════════════════════════════════════════════════════════

Start scan with this configuration?  [Y/n]: y

✨ Starting scan…
20:33:08 | INFO     | Scanvora     | 🔍 Querying crt.sh …
20:33:08 | INFO     | Scanvora     | 🔍 Querying HackerTarget …
20:33:08 | INFO     | Scanvora     | 🔍 Querying AlienVault OTX …
20:33:08 | INFO     | Scanvora     | 🔍 Querying Wayback Machine …
20:33:09 | INFO     | Scanvora     | ✅ HackerTarget: 20 subdomains
20:33:38 | ERROR    | Scanvora     | Wayback error:
20:34:08 | WARNING  | Scanvora     | ⏰ subfinder timed out — killing process
```

Fig 2: Scan configuration summary and live log output during the hackthissite.org passive OSINT scan.

Screenshot 3 — Output Files Stored

On scan completion Scanvora automatically writes two timestamped report files to disk — a **.json** machine-readable report and a **.txt** human-readable summary. The screenshot confirms both file pairs from two separate scan runs.

Fig 3: Output directory showing JSON and TXT report files generated for hackthissite.org across two scan timestamps.

Live Scan Target — hackthissite.org

All screenshots were captured during a live scan against **hackthissite.org** — a dedicated legal hacking practice platform that explicitly permits security research and automated reconnaissance. No unauthorised systems were targeted. The scan ran in Passive OSINT Only mode (no brute force, no paid APIs) demonstrating the tool's stealthy, non-intrusive enumeration capability.

Key Observations

OSINT Coverage: Six passive sources combined returned substantially more unique subdomains than any single source alone. Certificate Transparency logs (crt.sh) and HackerTarget consistently provided the highest yield.

Wildcard DNS Impact: hackthissite.org uses wildcard DNS for some of its subdomains. Without the WildcardDetector pre-filter, hundreds of false-positive live subdomains would have polluted the results.

subfinder Timeout: The optional subfinder process timed out during the test run (as visible in the screenshot). The graceful timeout handler killed the process and the scan continued without interruption — demonstrating the robustness of the async architecture.

Output File Utility: The dual JSON + TXT output format makes Scanvora practical for both automated pipeline integration (JSON) and quick human review during engagements (TXT).

Rate Limiting Effectiveness: Running at 120 RPM with concurrency 40 kept the scan within safe bounds for free-tier APIs while completing enumeration in under 2 minutes for a medium-sized domain.

Conclusion

Scanvora v5.1 fully satisfies all deliverables set out in the Black Byt3 Fellowship Task 2 specification. It implements both brute-force and API-based subdomain enumeration, automated live-host verification, private/public IP classification, and Shodan enrichment for CVE and open-port data — all wrapped in a polished interactive wizard with a named author banner.

Building this tool deepened my practical understanding of asynchronous Python networking, DNS internals, certificate transparency, and the OSINT ecosystem. More importantly, it reinforced how much attack surface information is freely and passively available for any domain — and why subdomain enumeration is the essential first step in every professional reconnaissance workflow.

All scanning was performed against hackthissite.org, a platform that explicitly authorises security research. No unauthorised systems were accessed.

Muhammad Hozaifa Naeem | Black Byt3 | April 21, 2026